

Registre de risques				
A. Technique & Infrastructure				
ID	Risque (cause)	Gravité	P	G
T-01	Panne hébergeur / indisponibilité du site	Site inaccessible, perte d'utilisateurs, mauvaise image	3	4
T-02	Mauvaise configuration DNS ou expiration du nom de domaine	Site introuvable, interruption du service	2	4
T-03	Plugins ou dépendances non mis à jour	Vulnérabilités, erreurs d'affichage, plantage du site	4	4
T-04	Faibles de sécurité (formulaires, injections, XSS)	Piratage, perte ou vol de données, dégradation du site	3	5
T-05	Accès non autorisé aux favoris d'un autre utilisateur (partage d'URL ou identifiant non protégé).	Atteinte à la confidentialité, perte de confiance des utilisateurs.	3	4
T-06	Perte de données suite à une erreur technique ou à l'absence de sauvegarde récente.	Suppression accidentelle du contenu du site ou des comptes utilisateurs.	2	5
T-07	Surcharge du site (pic de trafic lors d'un événement)	Ralentissements, bugs d'affichage, erreurs 500	4	3

T-08	Fuite d'informations sensibles (clés API, mots de passe)	Piratage, spam, perte d'accès aux services liés	2	5
T-09	Non-conformité accessibilité (texte illisible, navigation difficile)	Mauvaise expérience utilisateur, exclusion de certains visiteurs	3	3
B. Sécurité & Vie privée (inclut Newsletter & Favoris)				
ID	Risque (cause)	Gravité	P	G
P-01	Absence de lien de désinscription dans la newsletter	Risque de plainte CNIL, mauvaise image du site	3	4
P-02	Personnalisation incorrecte des emails (mauvais prénom, oubli, erreur)	Impression de spam, perte de confiance des abonnés	4	2
P-03	Conservation excessive des données utilisateurs (newsletter ou comptes inactifs)	Non-respect du principe de minimisation RGPD	3	3

P-04	Fuite ou piratage des emails ou favoris (violation de données personnelles).	Notification CNIL obligatoire, perte de confiance.	2	4
P-05	Utilisation d'un outil d'emailing non conforme (hors UE ou non sécurisé)	Transfert de données hors UE, non-conformité RGPD	2	5
P-06	Absence de gestion des droits RGPD (accès, suppression, modification)	Risque de plainte utilisateur ou CNIL	3	4
P-07	Favoris visibles par d'autres utilisateurs (mauvaise gestion d'accès)	Violation de la vie privée, perte de confiance	3	4
P-08	Absence de politique de confidentialité claire sur le site	Non-transparence vis-à-vis des utilisateurs	3	3
P-09	Logs ou fichiers de suivi contenant des informations personnelles	Risque de fuite indirecte (ex : adresses mail dans les journaux d'erreurs)	3	3
P-10	Création de comptes par des mineurs (moins de 16 ans)	Non-conformité RGPD, risque légal	2	4
C. Juridique / Contenus / Communauté				

ID	Risque	Gravité	P	G
L-01	Utilisation d'images, logos ou textes sans droits	Retrait du contenu, plainte pour violation de droits d'auteur, mauvaise image	3	4
L-02	Publication d'avis ou commentaires inappropriés (diffamatoires, racistes, insultants)	Responsabilité légale du site, atteinte à la réputation	3	4
L-3	Informations erronées (prix, adresses, horaires, lieux fermés)	Perte de crédibilité, insatisfaction utilisateur	4	3
L-04	Informations trompeuses ou exagérées ("bons plans" volontairement embellis ou non réels)	Risque de signalement pour publicité trompeuse, perte de confiance des utilisateurs	2	4
L-05	Absence d'avertissement pour certaines activités (danger, fermeture, météo)	Mise en cause du site en cas d'incident, perte de crédibilité du site	2	4
L-06	Manque de transparence sur les liens ou partenariats (affiliation, réductions, sponsors)	Risque de sanction pour publicité dissimulée, perte de confiance des utilisateurs	2	3
L-07	Absence de mentions légales obligatoires sur le site	Non-conformité légale, retrait possible du site	2	3

L-08	Absence de CGU (conditions d'utilisation)	Conflits ou incompréhensions sur les règles d'usage du site	3	3
L-09	Non-respect du droit à la modération (absence de procédure de signalement)	Risque de laisser des propos illégaux ou sensibles	3	3
D. Opérationnel & Organisation				
ID	Risque	Gravité	P	G
O-01	Rôles flous / SPOF (un seul développeur)	Retards, surcharge de travail, dette technique	4	3
O-02	Calendrier éditorial non respecté	Contenus obsolètes, manque de régularité	3	3
O-03	Absence de plan d'incident	Réactions désorganisées en cas de bug ou panne	2	4

O-04	Vendor lock-in (dépendance à un seul outil externe : emailing, cartes, etc.)	Difficulté à changer d'outil si panne ou coût élevé	3	3
O-05	Budget campagnes email non maîtrisé	Perte financière si trop d'envois sans résultat	3	2
O-06	Examens / périodes chargées (disponibilité limitée)	Retards dans la roadmap ou livraison du site	4	2
E. Qualité des données & UX				
ID	Risque	Gravité	P	G
Q-01	Adresses/itinéraires imprécis	Mauvaise expérience utilisateur, perte de crédibilité	3	3
Q-02	Accessibilité numérique insuffisante (contraste, balises ALT, navigation clavier, taille du texte)	Exclusion de certains utilisateurs, baisse du référencement (SEO)	3	3

Q-03	Traductions approximatives (pour les destinations européennes)	Confusion, perte de crédibilité	2	2
Q-04	SEO dégradé (contenu dupliqué, IA, ou manque de structure)	Chute du trafic sur le site, mauvaise visibilité Google	3	3
F. Emailing & Délivrabilité (Newsletter)				
ID	Risque	Gravité	P	G
M-01	SPF / DKIM / DMARC absents	Emails bloqués ou envoyés dans le dossier spam	3	4
M-02	Taux de spam et désabonnements élevés	Baisse du score de réputation du domaine, perte d'abonnés	3	3
M-03	Bounces non gérés (emails retournés non livrés)	Risque de blacklist par les fournisseurs de messagerie	3	3

M-04	Sur-personnalisation des emails (segments trop précis)	Sentiment d'intrusion, perte de confiance	2	3

Niveau	Mesures préventives (avant)
12 Élevé	Utiliser un hébergeur mutualisé fiable (OVH, Hostinger, Netlify), effectuer des sauvegardes hebdomadaires sur Google Drive, surveiller le site via UptimeRobot (gratuit).
8 Moyen	Annexé les favoris des utilisateurs au cas ou, tester les accès utilisateurs après chaque modification du code.
16 Élevé	Effectuer les mises à jour des modules ou plugins (WordPress, CMS, dépendances JS) après chaque modification du site.
15 Élevé	Sécuriser les formulaires (validation côté serveur), utiliser HTTPS (certificat Let's Encrypt gratuit), limiter les permissions.
12 Élevé	Authentification et autorisations robustes (AuthN/AuthZ), vérification des droits d'accès, utilisation d'IDs aléatoires non devinables.
10 Élevé	Réaliser des sauvegardes manuelles avant chaque mise à jour importante ou présentation, en conservant au moins deux versions sur des supports distincts (Google Drive et GitHub privé).
12 Élevé	Optimiser le poids des images, compresser les fichiers, tester le site avant la soutenance.

10 Élevé	Stocker les identifiants dans un fichier .env local non publié, ne jamais les mettre sur GitHub, limiter les accès.
9 Moyen	Vérifier le contraste des couleurs, la taille du texte, l'ajout de balises "alt" sur les images, test clavier.
Niveau	Mesures préventives
12 Élevé	Intégrer un lien "Se désabonner" dans chaque email, tester son bon fonctionnement.
8 Moyen	Stocker les prénoms dans une base simple et vérifier leur format, prévoir un message neutre si le prénom est manquant ("Bonjour à toi !").
9 Moyen	Supprimer les comptes ou emails inactifs depuis plus de 3 ans

8 Moyen	Restreindre les accès à la base de données, sauvegarder sur espace sécurisé (Drive privé, GitHub privé).
10 Élevé	Utiliser un prestataire européen (Brevo) pour envoyer les newsletters.
12 Élevé	Créer une adresse simple “contact@...” pour que les utilisateurs puissent demander la suppression ou l'accès à leurs données.
12 Élevé	Favoris privés par défaut, pas de lien public.
9 Moyen	Rédiger une page “Politique de confidentialité” claire, simple et visible (données collectées, droits, contact).
9 Moyen	Éviter d'enregistrer des données sensibles dans les journaux, anonymiser les logs.
8 Moyen	Ajouter une mention “Site réservé aux étudiants de 16 ans et plus” et une case de confirmation d'âge à l'inscription.

Niv.	Prévention
12 Élevé	Utiliser uniquement des images libres de droit (Unsplash, Pexels, Pixabay), ou celles créées par l'équipe. Mentionner les crédits sous les images.
12 Élevé	Rédiger une charte de la communauté (respect, tolérance, interdiction de propos offensants). Prévoir un bouton "signaler un contenu", appliquer une modération avant chaque publication de commentaire.
12 Élevé	Vérifier les sources avant publication, indiquer la date de dernière mise à jour, éviter les affirmations non vérifiées.
8 Moyen	Indiquer systématiquement la source et préciser s'il s'agit d'une estimation, d'une offre temporaire ou approximative. Ne jamais exagérer les prix ou les réductions.
8 Moyen	Ajouter un disclaimer sur les pages concernées : "Vérifiez les horaires, la météo et les conditions avant votre visite."
6 Moyen	Si un jour il y a des partenaires, indiquer clairement "Lien partenaire" ou "Offre sponsorisée".
6 Moyen	Créer une page Mentions légales avec : noms des créateurs, hébergeur, contact mail et mention.

9 Moyen	Rédiger une page CGU simple (utilisation, interdictions, limites de responsabilité).
9 Moyen	Intégrer un bouton “Signaler un abus” sur les pages avec commentaires ou avis.
Niv.	Prévention
12 Élevé	Définir les rôles avec un tableau RACI (qui fait quoi), documenter les procédures, faire en sorte que chaque tâche puisse être reprise par un autre membre (“bus factor ≥ 2 ”).
9 Moyen	Tenir un planning de publication avec “owner” par ville / sujet, prévoir un backlog (liste de contenus à venir).
8 Moyen	Rédiger un petit plan d’incident (“runbook”) précisant les rôles et étapes en cas de problème technique.

9 Moyen	Choisir des outils avec réversibilité (export possible des données) et prévoir une alternative si un service tombe (ex. OpenStreetMap si Google Maps HS).
6 Moyen	Suivre des KPI simples : taux de clic (CTR)..., limiter les envois mensuels.
8 Moyen	Prévoir des sprints “light” pendant les semaines d’examens, répartir les tâches selon les disponibilités.
Niv.	Prévention
9 Moyen	Vérifier systématiquement les adresses et horaires sur des sources fiables (Google Maps, sites officiels). Intégrer une carte embarquée pour éviter les erreurs.
9 Moyen	Réaliser un mini audit RGAA : vérifier le contraste, la présence des textes alternatifs sur les images, la taille de police, et la navigation clavier.

4 Faible	Créer un glossaire interne (vocabulaire cohérent pour les pages multilingues). Relire les textes avant mise en ligne.
9 Moyen	Optimiser les pages avec des balises canonical, un maillage interne cohérent, et appliquer la logique E-E-A-T (Expertise, Expérience, Autorité, Fiabilité).
Niv.	Prévention
12 Élevé	Configurer les enregistrements DNS (SPF, DKIM, DMARC) avec test avant envoi. Ces protocoles valident l'identité de l'expéditeur.
9 Moyen	Envoyer à une fréquence modérée, avec du contenu pertinent et clair. Nettoyer la liste d'abonnés (suppression des adresses inactives).
9 Moyen	Activer le bounce handling automatique (distinction entre "hard bounce" = adresse invalide, et "soft bounce" = boîte pleine).

6 Moyen	Appliquer le principe de minimisation : ne collecter que les données nécessaires (email, prénom). Personnalisation légère uniquement, favoriser la relation de proximité avec un langage courant.

Détection / Réaction (pendant/après)	Responsable	Fréq. revue
Si panne : vérifier état chez l'hébergeur, restaurer sauvegarde la plus récente, informer via message temporaire sur la page d'accueil.	SARUJAN	Toute les 6 semaines ou après une mise à jour
Si bug : désactiver la fonctionnalité temporairement et corriger les droits d'accès.	SARUJAN	2 fois par an
En cas d'erreur : désactiver le plugin défectueux, restaurer version précédente.	SARUJAN	À chaque mise à jour
Si anomalie : fermer temporairement le formulaire concerné et corriger le code.	SARUJAN	À chaque nouvelle fonctionnalité
Surveillance des logs d'accès, correction immédiate en cas d'accès suspect, notification de l'utilisateur concerné.		À chaque ajout ou modification d'une fonctionnalité liée aux comptes utilisateurs.
Si perte : restaurer la dernière version stable.		À chaque mise à jour majeure
Si le site rame : désactiver temporairement certaines sections lourdes (cartes, images HD).		Avant chaque démonstration ou maintenance.

Si fuite : régénérer les clés API, changer les mots de passe, supprimer les anciennes versions.		Après chaque mise en ligne
Corriger le design si problèmes signalés (texte trop petit, boutons invisibles).		Avant chaque rendu ou mise à jour
Détection / Réaction	Responsable	Fréq.
Si problème : arrêt temporaire des envois, correction du lien, informer les abonnés.		Mensuel
Corriger les erreurs dans la base, vérifier avant chaque envoi massif.		Mensuel
Nettoyage manuel régulier de la base de données, vérification des doublons.		Trimestriel

En cas de fuite, notifier la CNIL et les utilisateurs sous 72h, réinitialiser les accès.		Annuel
Si non-conformité détectée : basculer vers un autre prestataire, informer les abonnés.		Trimestriel
Répondre aux demandes sous 30 jours maximum (délai légal RGPD), supprimer les données concernées et conserver une preuve de suppression.		Trimestriel
Tester les accès après chaque mise à jour du code, corriger toute faille détectée.		À chaque mise à jour
Ajouter ou corriger la page si absence ou erreur, communiquer sur la mise à jour.		Trimestriel
Supprimer les logs trop détaillés ou anciens, nettoyer les serveurs.		Trimestriel
Supprimer les comptes non conformes si détectés.		Supprimer les comptes non conformes si détectés ou signalés.

Détection / Réaction	Responsable	Revue
Supprimer immédiatement le contenu litigieux, remplacer par une image libre de droit, informer la personne concernée.		Mensuel
Supprimer le commentaire sous 24-48h, avertir l'utilisateur, conserver une trace de la modération.		Hebdomadaire
Corriger rapidement, afficher "Mise à jour en cours" sur la page concernée.		Mensuel
Corriger les informations, publier un message de rectification.		Trimestriel
Ajout ou correction de l'avertissement, notifier l'équipe si signalement.		Trimestriel
Ajout de la mention manquante sur la page, informer les utilisateurs.		Trimestriel
Ajouter la page immédiatement si oubli, vérifier qu'elle reste accessible depuis le pied de page.		Trimestriel

Ajouter ou corriger la page, informer les utilisateurs si changements.		Semestriel
Supprimer le contenu en moins de 48h après modération, garder une trace des signalements.		Hebdomadaire
Détection / Réaction	Responsable	Revue
Suivre les jalons du projet, redistribuer les tâches en cas d'absence ou de surcharge.		Mensuel
Recevoir une alerte si un contenu n'a pas été mis à jour depuis >90 jours, faire une rotation entre membres pour publication.		Mensuel
Faire un post-mortem après incident (analyse de ce qui s'est passé), corriger pour éviter que ça se reproduise.		Trimestriel

Tester un plan de bascule au moins une fois (changer temporairement d'outil pour voir si tout fonctionne).		Annuel
Si coût excessif → faire pause dans les envois, réduire la fréquence, revoir le ciblage.		Mensuel
Reprioriser rapidement les objectifs, reporter les tâches non urgentes.		Mensuel
Détection / Réaction	Responsable	Revue
Ajouter un bouton "Signaler une erreur" pour que les utilisateurs puissent remonter les problèmes. Corriger dans la semaine.		Mensuel
Mettre en place des correctifs après chaque test utilisateur ou retour d'accessibilité.		Trimestriel

Corriger les fautes ou imprécisions grâce aux retours de la communauté ou d'un membre bilingue.		Trimestriel
Nettoyer les contenus dupliqués, mettre en place des redirections et vérifier l'indexation dans la Search Console.		Mensuel
Détection / Réaction	Responsable	Revue
Tester régulièrement le score spam (MailTester, GlockApps), corriger les erreurs DNS si blocage.		Mensuel
En cas de chute d'engagement : pause des envois, mise à jour des listes, demande de re-optin (nouvelle confirmation d'abonnement).		Mensuel
Supprimer les adresses invalides.		Mensuel

Réduire les variables utilisées dans les emails et expliquer clairement la logique de personnalisation dans la politique vie privée.		Trimestriel

					Critique	0
12	Élevé				Élevé	7
8	Moyen				Moyen	2
16	Élevé				Faible	0
15	Élevé					
12	Élevé					
10	Élevé					
12	Élevé					

10	Élevé					
9	Moyen					
12	Élevé			Critique	0	
8	Moyen			Élevé	4	
9	Moyen			Moyen	6	

	8 Moyen			Faible	0	
	10 Élevé					
	12 Élevé					
	12 Élevé					
	9 Moyen					
	9 Moyen					
	8 Moyen					

12	Élevé					
12	Élevé					
12	Élevé		Critique	0		
8	Moyen		Élevé	3		
8	Moyen		Moyen	6		
6	Moyen		Faible	0		
6	Moyen					

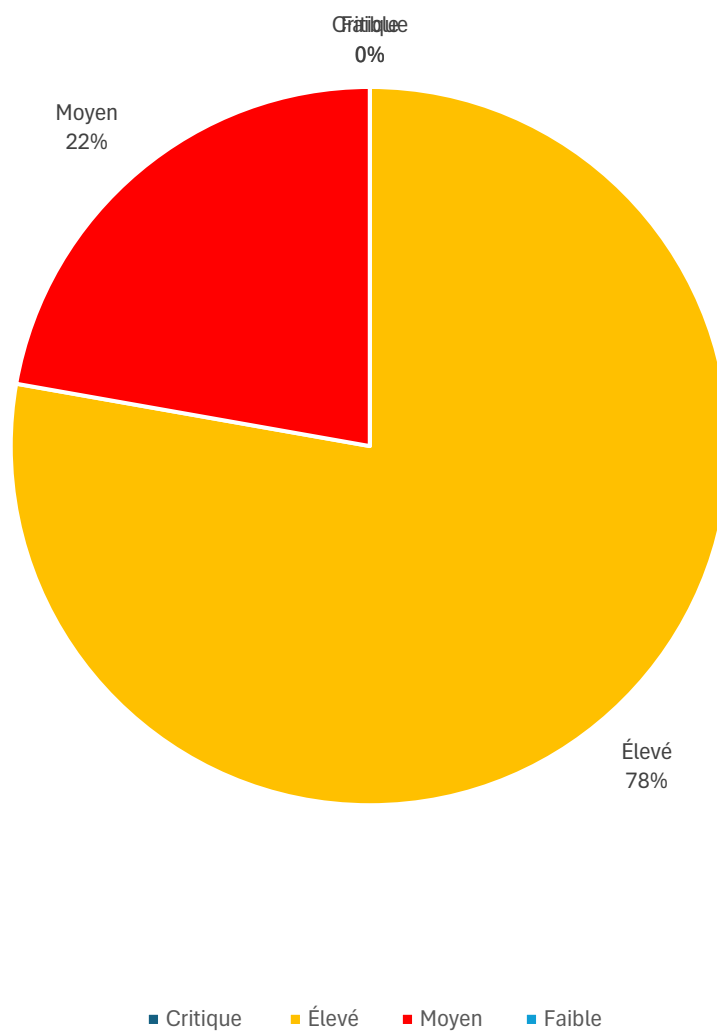
9	Moyen					
9	Moyen					
12	Élevé					
9	Moyen					
8	Moyen		Critique	0		

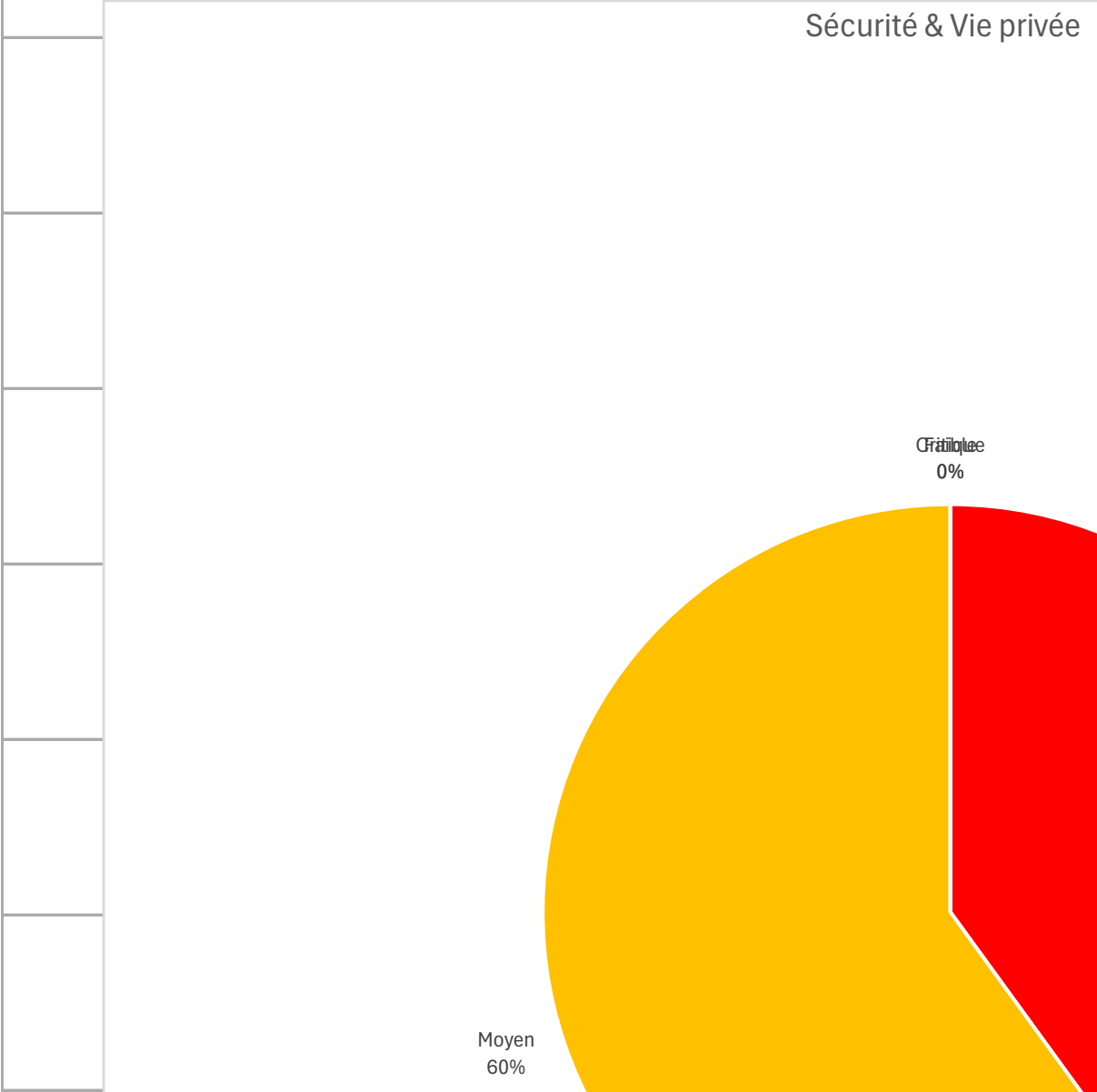
9 Moyen			Élevé	1		
6 Moyen			Moyen	5		
8 Moyen			Faible	0		
9 Moyen						
9 Moyen						

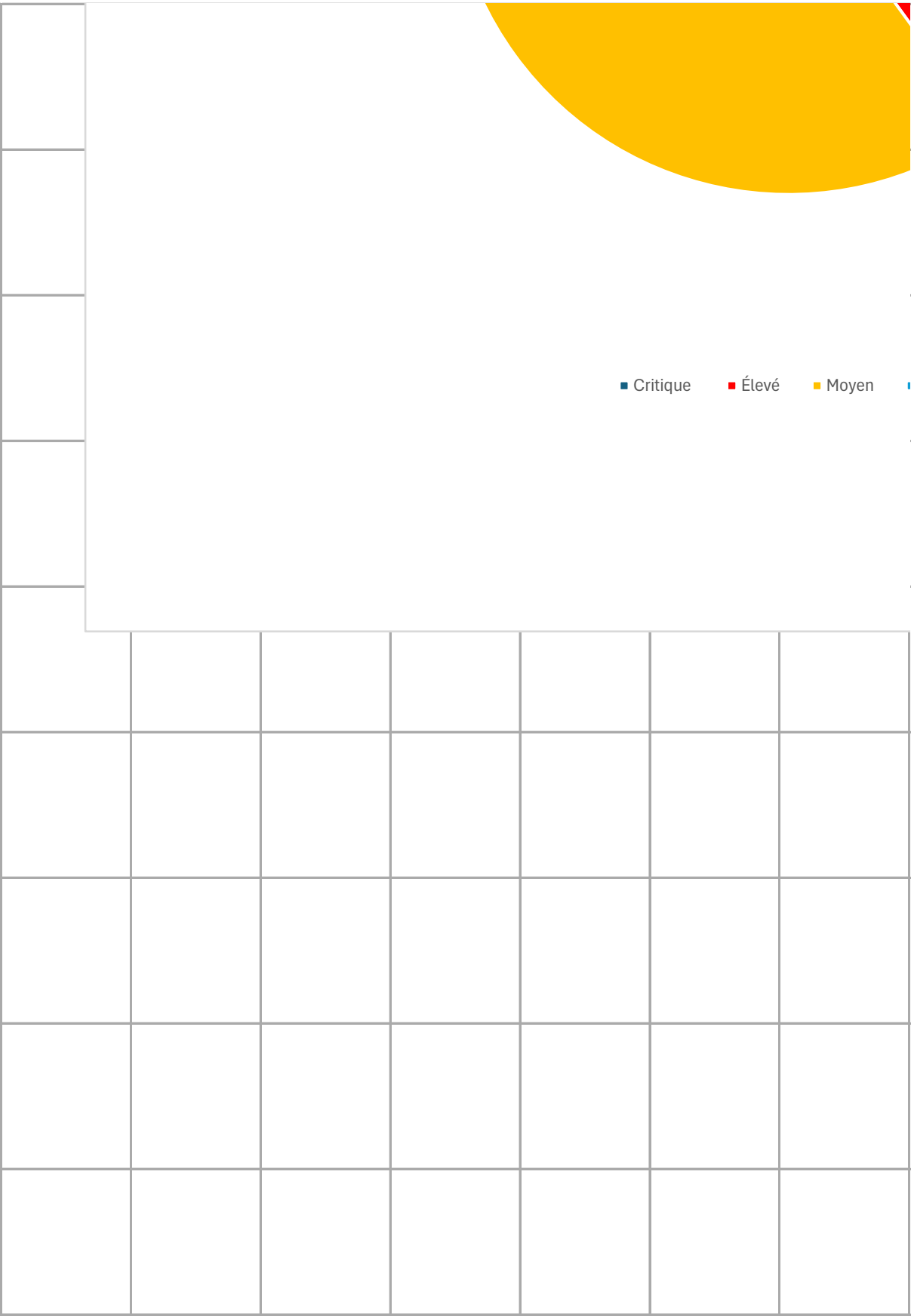
4	Faible		Critique	0		
9	Moyen		Élevé	0		
			Moyen	3		
			Faible	1		
12	Élevé					
9	Moyen					
9	Moyen		Critique	0		

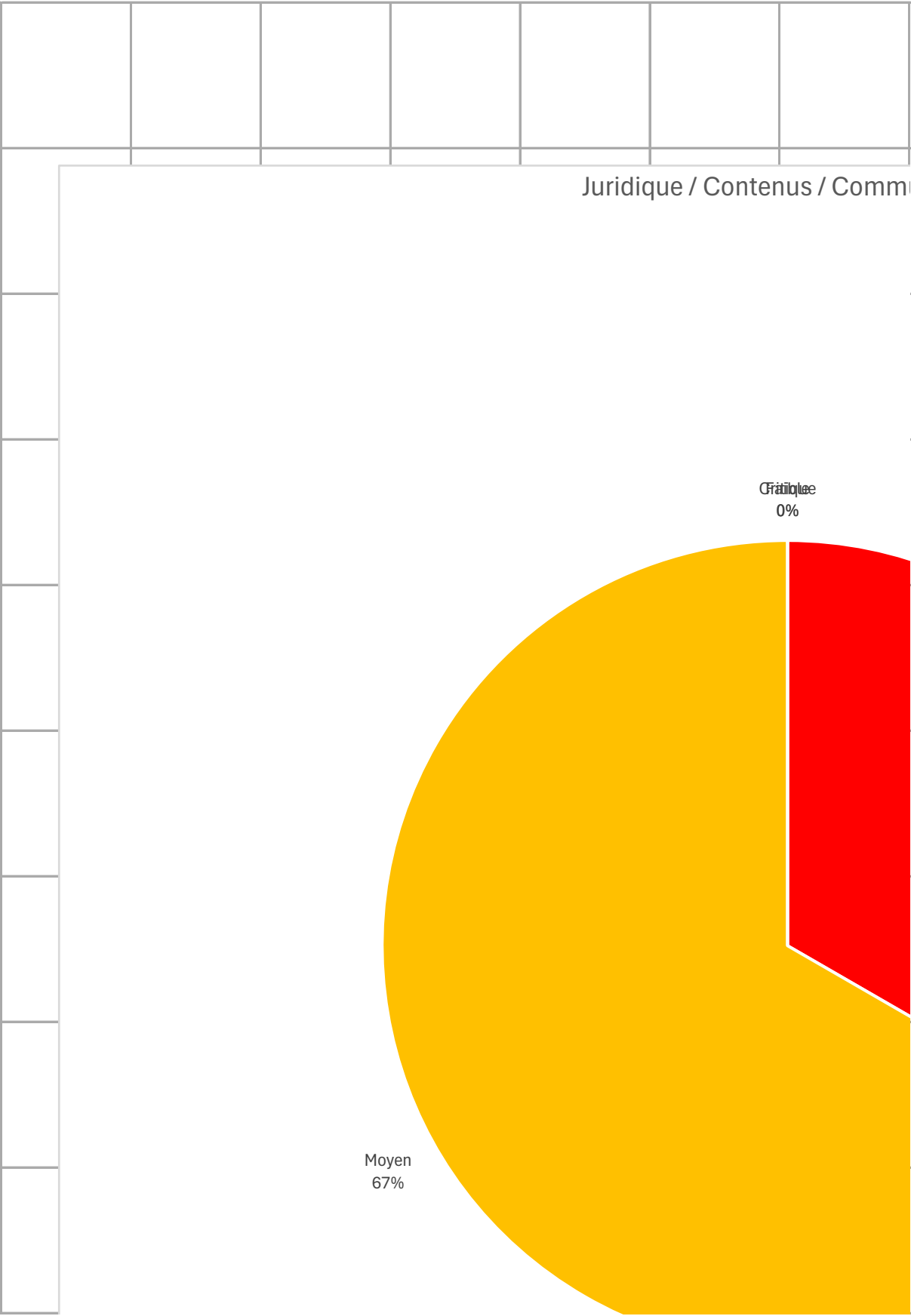
	6 Moyen		Élevé	1		
			Moyen	3		
			Faible	0		

Risques Technique & Infrastructure

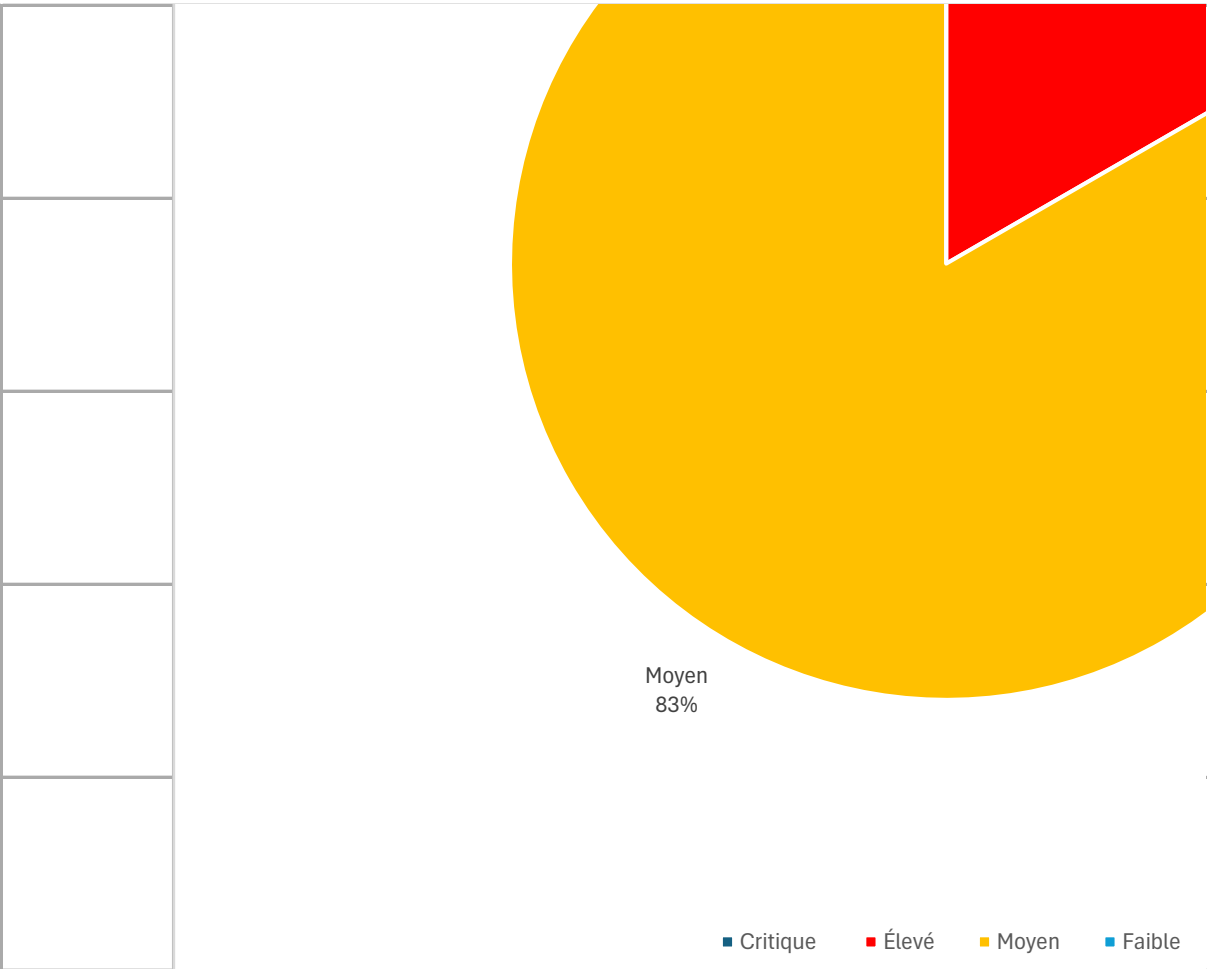




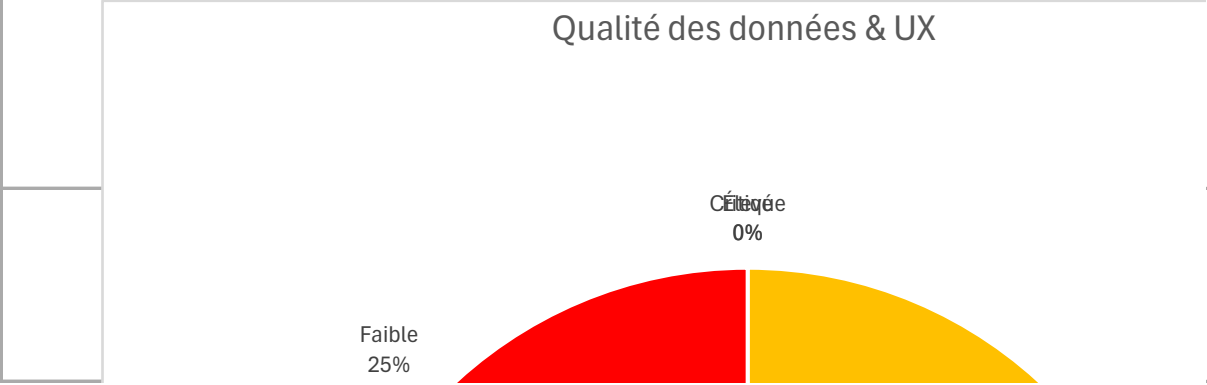


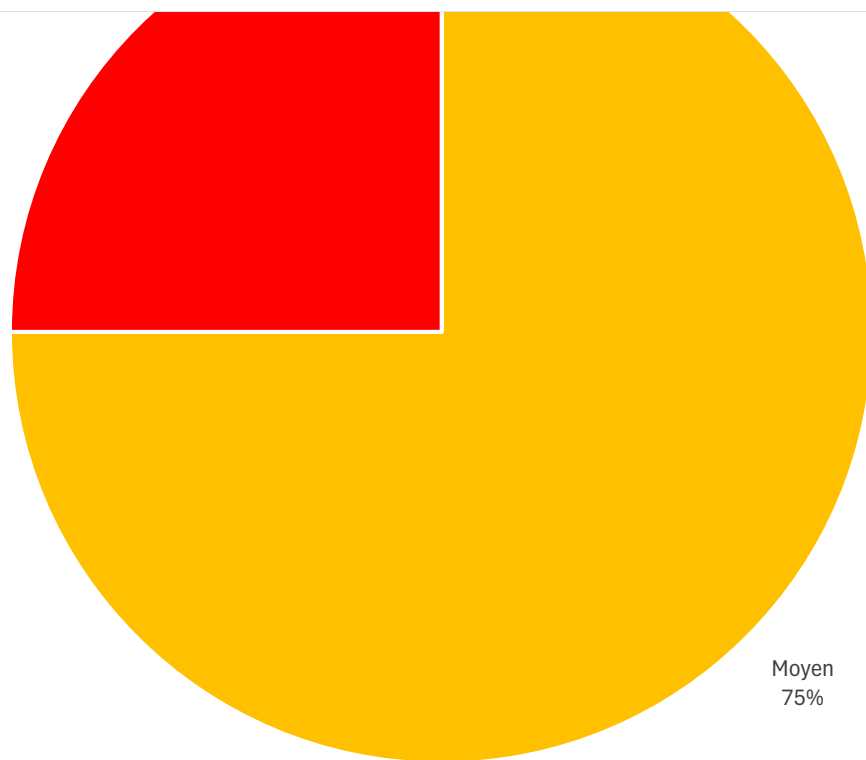






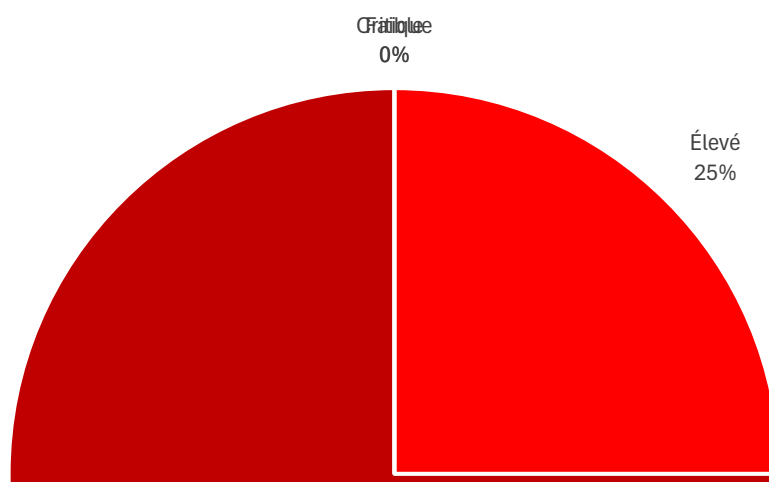
Qualité des données & UX

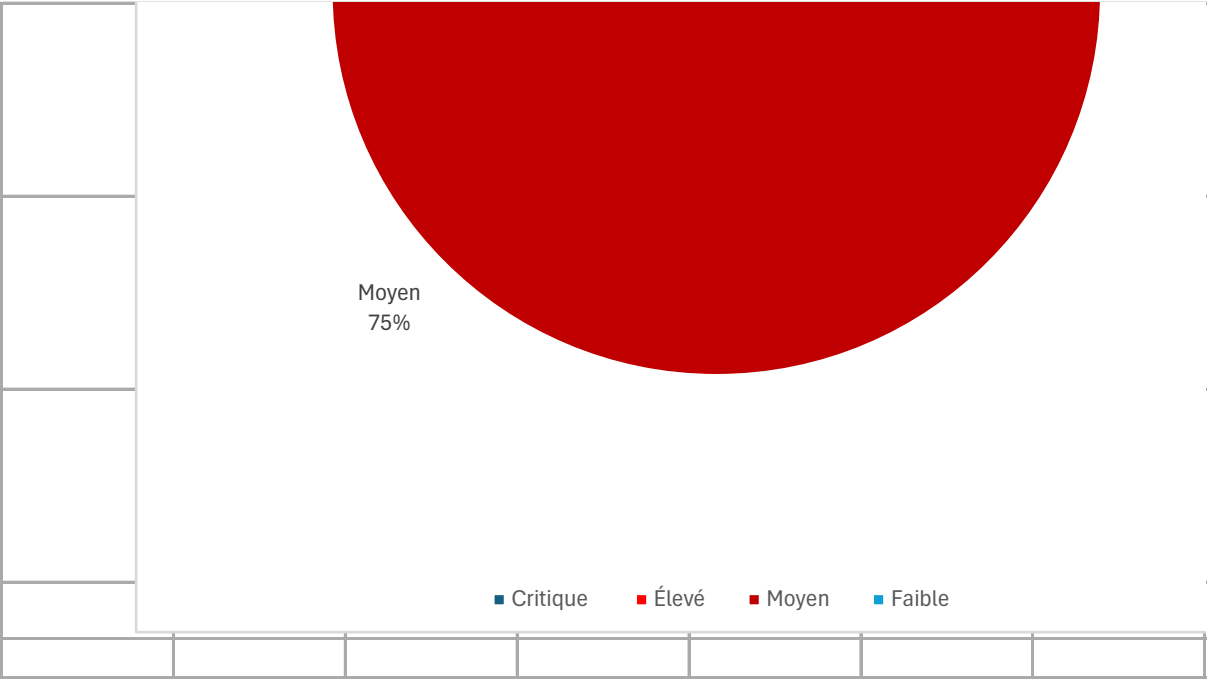


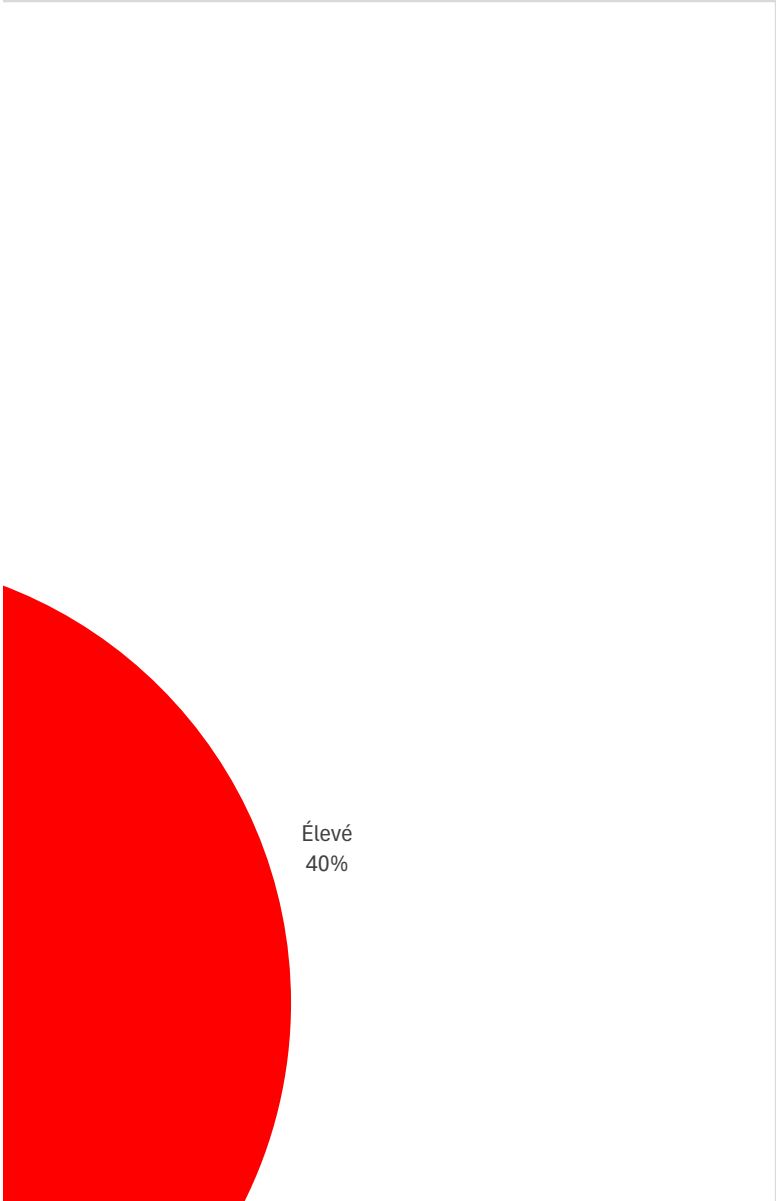


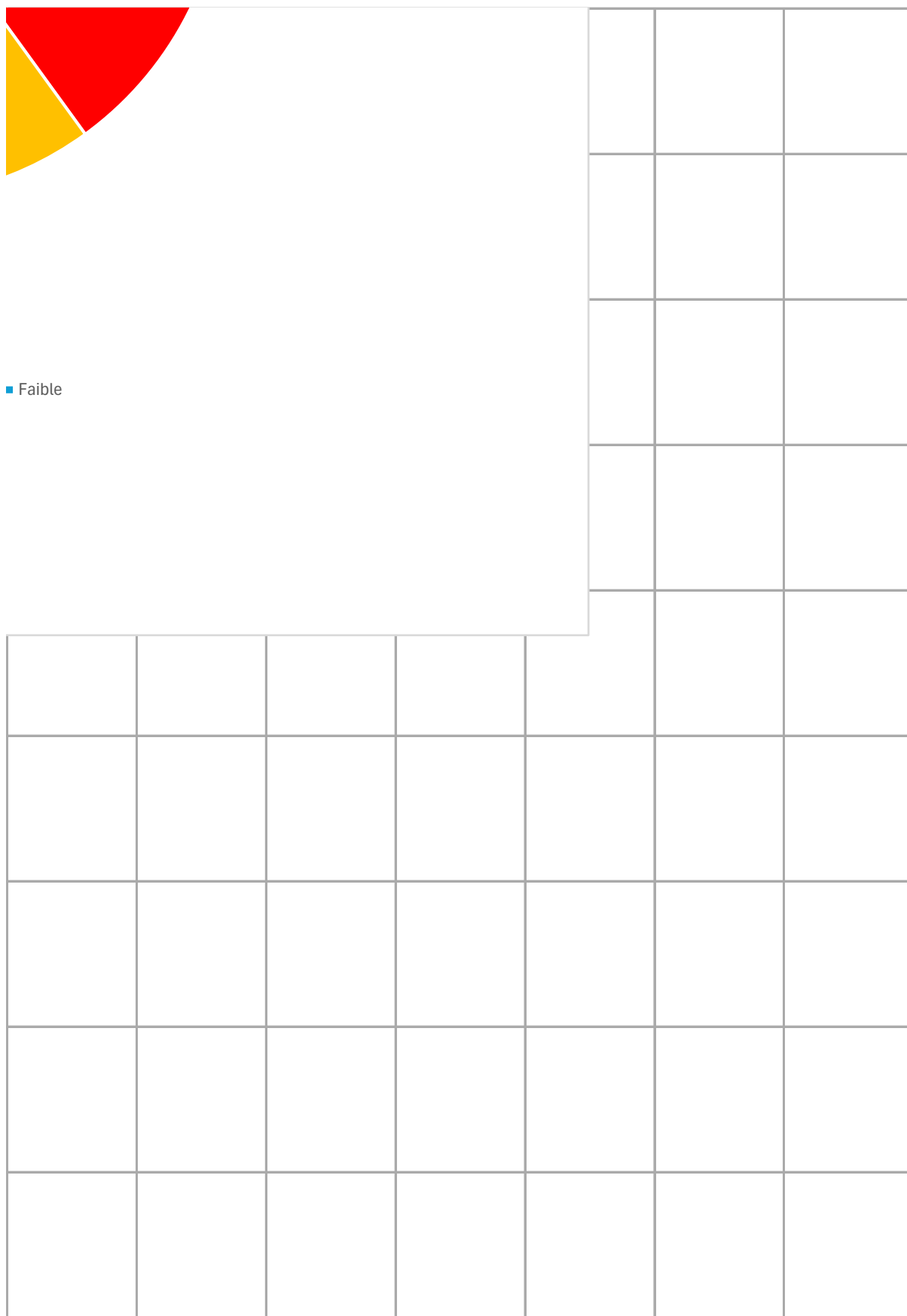
■ Critique ■ Élevé ■ Moyen ■ Faible

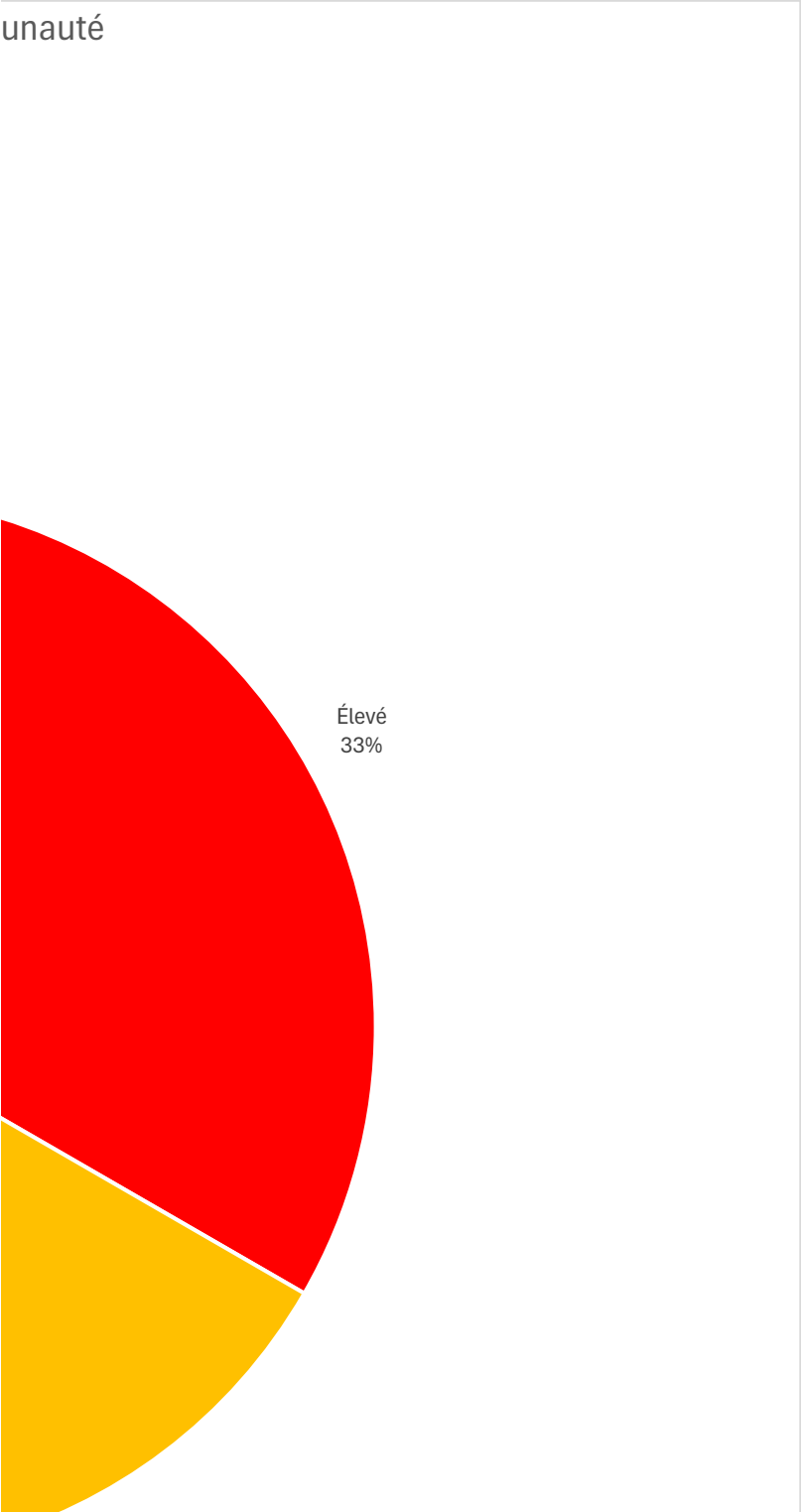
Emailing & Délivrabilité





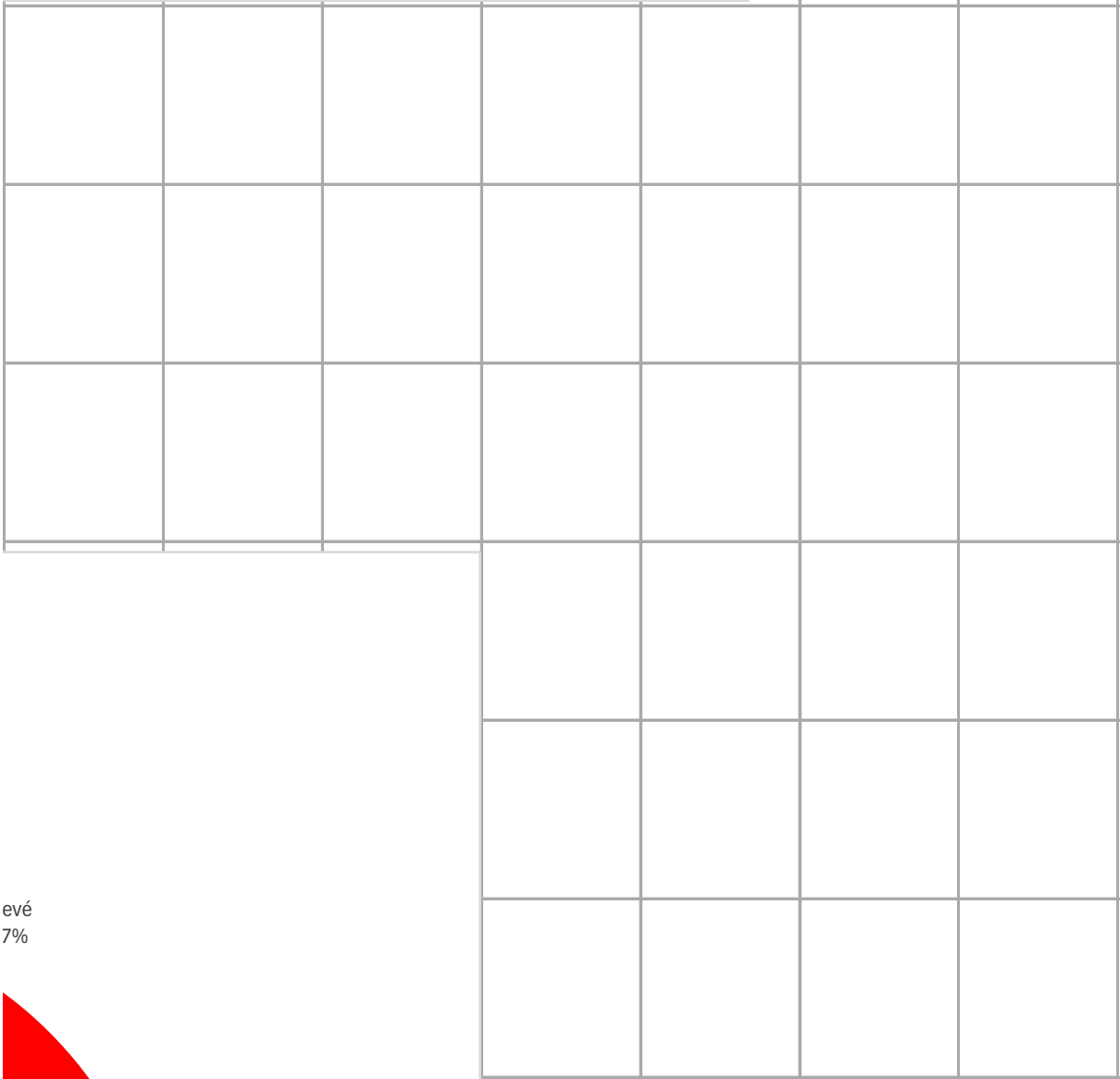






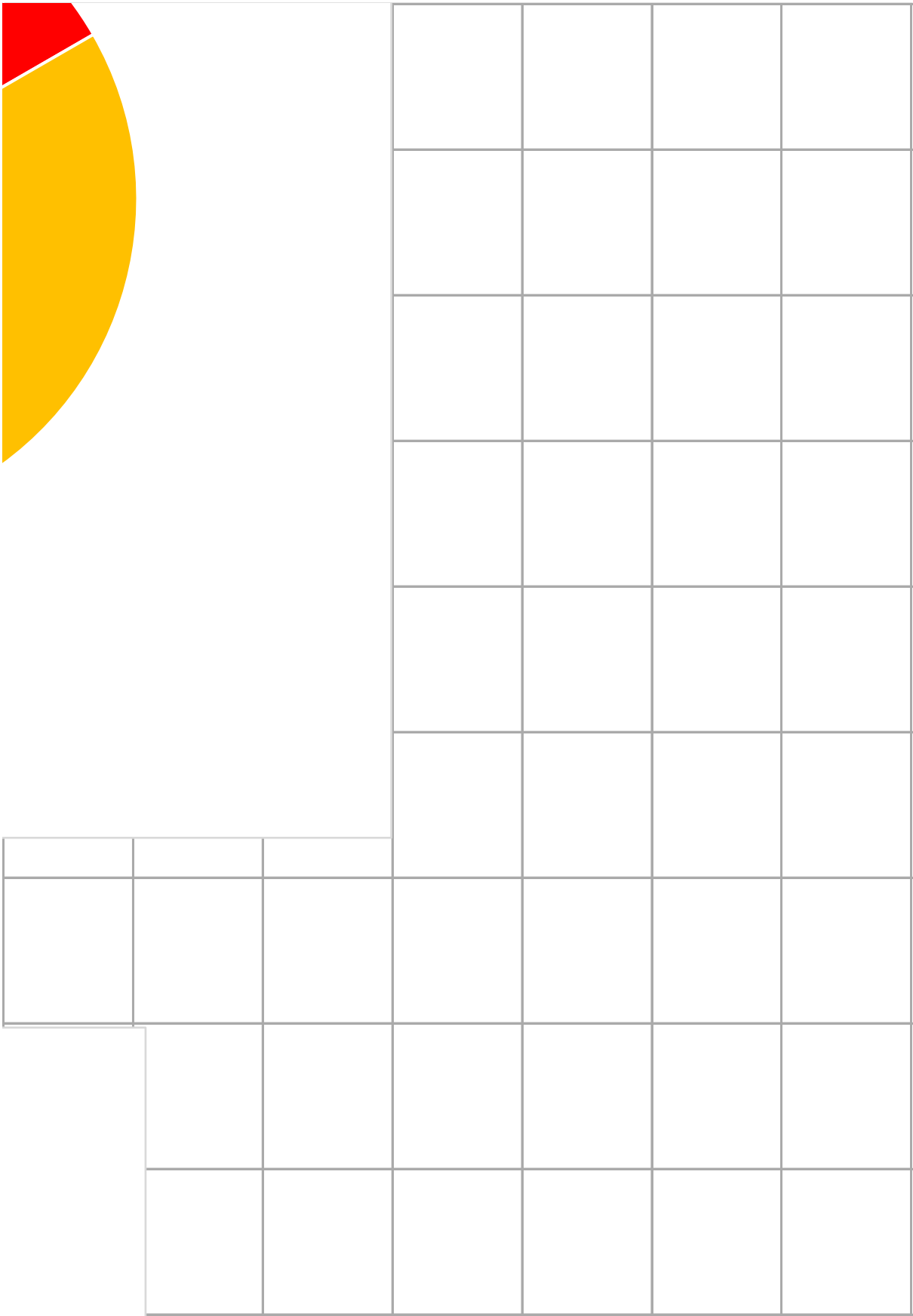


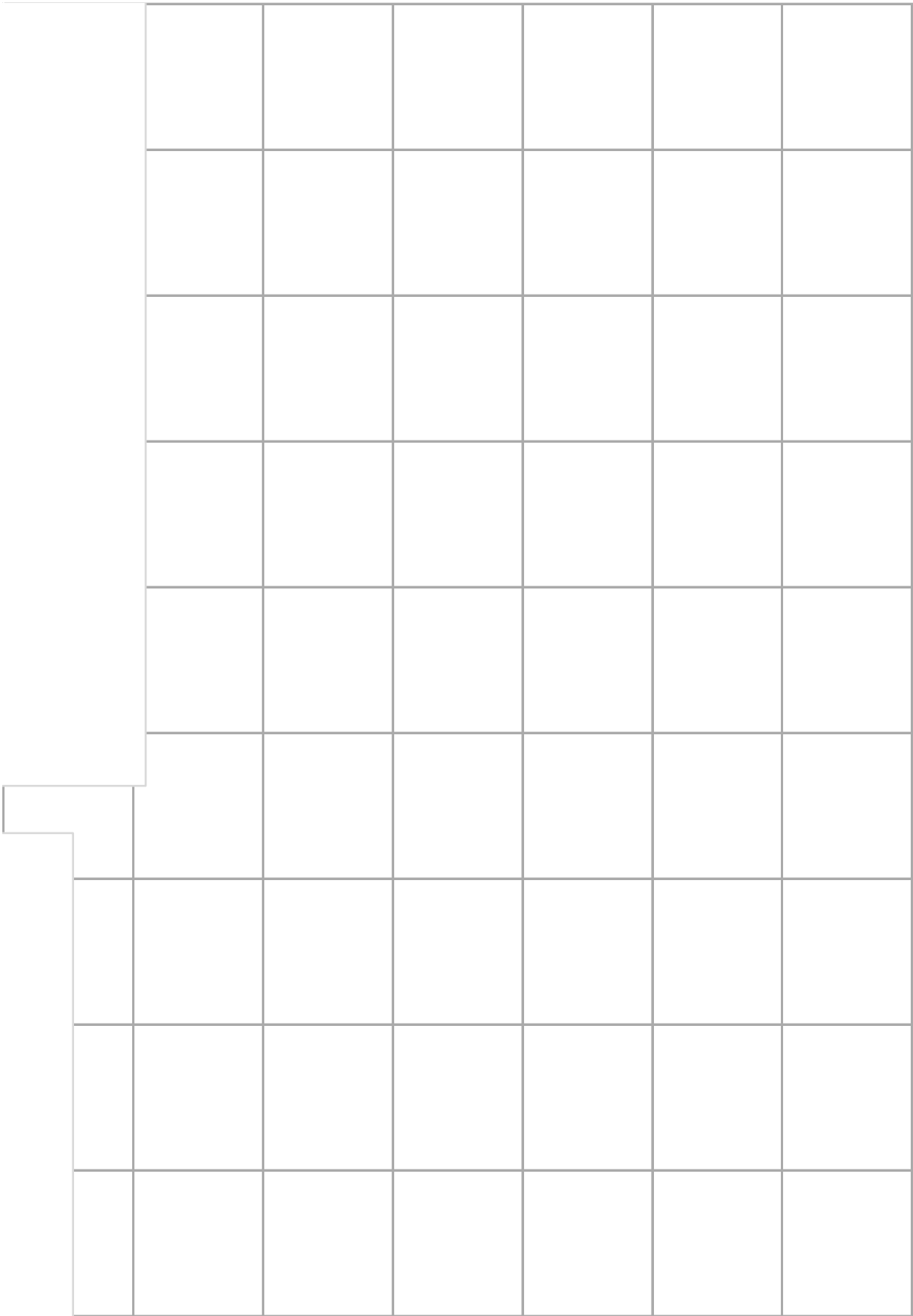
■ Faible



evé
7%







GRILLE DE SCORING				
Échelle	Probabilité (P)	Gravité / Impact (G)		
1	Très peu probable (≤1 fois/an)	Impact mineur (inconfort UX)		
2	Peu probable	Impact limité (petit incident)		
3	Possible	Impact notable (fonction dégradée, plainte ponctuelle)		
4	Probable	Impact élevé (interruption service, plainte CNIL potentielle)		
5	Très probable / récurrent	Impact critique (data breach, mise en cause juridique, forte perte d'image)		
Niveau de risque = P × G → Seuils : 1–4 faible, 5–9 moyen, 10–16 élevé, 17–25 critique.				

Mini-registre RGPD – Newsletter & Favoris				
Traitement A — Newsletter (emails + prénom pour personnalisation)				
Finalité :				
Envoi d’emails d’information et de bons plans personnalisés (salutation “Bonjour {Prénom}”).				
Base légale :				
Consentement — <i>article 6(1)(a) du RGPD</i> , via double opt-in (confirmation par email après inscription).				
Données traitées :				
Email (<i>obligatoire</i>)				
Prénom (<i>facultatif mais recommandé pour la personnalisation</i>)				
Aucune donnée sensible collectée.				
Provenance :				
Formulaires d’inscription intégrés sur le site.				
Responsable désigné :				
Une personne désignée (référente “communication / envoi newsletter”).				
Sous-traitants :				
Prestataire emailing européen (ex. Brevo, Mailjet).				
Transferts hors UE :				
Non — uniquement via prestataire basé dans l’Union européenne.				
Durée de conservation :				
Jusqu’à désinscription ou inactivité prolongée.				
Purge automatique 3 ans après le dernier contact ou immédiate en cas de désinscription .				
Mesures de sécurité :				
Chiffrement des données au repos et en transit (TLS 1.3)				
Journalisation du consentement (date + IP)				
Liens de désinscription 1-clic				
Authentification d’envoi : SPF / DKIM / DMARC				
Accès limité à la personne désignée uniquement				

Droits des personnes :				
Accès, rectification, suppression, opposition (art. 15 à 22 RGPD)				
→ via le lien en pied d'email ou la page "Mes données".				
Analyse d'impact (DPIA) :				
Non nécessaire (faible volume, pas de données sensibles, pas de profilage massif).				
À réévaluer si la base dépasse 10 000 abonnés .				
Note UX :				
Si le prénom n'est pas renseigné → message neutre : "Bonjour".				
Traitement B — Comptes & Favoris (sauvegarde des itinéraires et activités)				
Finalité :				
Permettre aux utilisateurs de créer un compte et d'enregistrer leurs favoris (itinéraires, activités, journées)				
Base légale :				
Article 6(1)(b) — exécution du contrat / CGU				
Article 6(1)(f) — intérêt légitime du responsable pour assurer la sécurité et le bon fonctionnement				
Données traitées :				
Email (identifiant de connexion)				
Mot de passe (<i>haché via bcrypt ou argon2</i>)				
Liste de favoris (<i>titre, ville, ID, date</i>)				
Horodatage des connexions				
Paramètres de confidentialité :				
Favoris privés par défaut				
Partage public uniquement sur opt-in explicite (case à cocher volontaire)				
Responsable désigné :				
Une personne référente "technique / gestion du site".				
Sous-traitants :				

Aucun tiers. Hébergement et traitement des données internes au site (hébergeur UE).

Transferts hors UE :				
Non.				
Durée de conservation :				
Compte actif : données conservées.				
Suppression 24 mois après la dernière connexion , avec pré-alerte 30 jours avant suppression.				
Sauvegardes limitées à 30-90 jours maximum.				
Mesures de sécurité :				
Hachage des mots de passe (bcrypt/argon2)				
HTTPS (TLS 1.3)				
Chiffrement au repos				
Contrôle d'accès strict (ACL)				
Journal d'accès pseudonymisé				
Aucun stockage de localisation GPS ou données sensibles.				
Droits des personnes :				
Export JSON/CSV, suppression du compte ou des favoris à tout moment.				
Délai de réponse : 30 jours maximum.				
Analyse d'impact (DPIA) :				
Non requise à ce stade.				

Réévaluer en cas d'évolution majeure (ex. >100 000 comptes ou intégration de géolocalisation).

es types).

Contrôles clés & Plan d'action 30 jours

Catégorie	Éléments de contrôle
Consentement & données	- CMP cookies conforme (refus par défaut, consentement granulaire).
	- Double opt-in newsletter activé + preuve du consentement enregistrée.
	- Lien de désinscription 1-clic fonctionnel sur tous les emails.
Emailing & sécurité	- SPF / DKIM / DMARC configurés + test de délivrabilité réussi.
	- Aucun transfert hors UE (prestataire emailing européen).
Comptes & Favoris	- Favoris privés par défaut , partage public uniquement sur opt-in explicite.
	- URLs non devinables (hash ou ID aléatoire).
Accès & journaux	- Accès limités à une personne désignée (principe RBAC simplifié).
	- Journaux d'accès pseudonymisés, sans données personnelles.
Sauvegardes & reprise	- Backups chiffrés .
	- Test de restauration effectué avec succès.
Sécurité applicative	- Audit OWASP basique (XSS / CSRF / IDOR / SQLi) effectué + correctifs appliqués.
	- Logs d'erreurs vérifiés et anonymisés.

Conformité légale & affichage	- Mentions légales, CGU, Politique de confidentialité, Charte de communauté en ligne et accessibles.
	- Politique cookies + CMP publiée.
Contenu & fiabilité	- Disclaimer sécurité sur les fiches sensibles (horaires, météo, transports susceptibles de changer).
	- Calendrier éditorial maintenu avec date de dernière mise à jour sur chaque fiche.

Accessibilité & UX	- Vérification du contraste , navigation clavier , balises alt , et lisibilité des textes .
Semaine	Objectifs principaux
Semaine 1	Mise en conformité de base
Semaine 2	Sécurisation et gestion des comptes

Semaine 3	Vérification technique et tests de sécurité
Semaine 4	Processus et mise en production

--	--

--	--

Politiques & pages à publier

--	--

Page / Politique	Contenu obligatoire
Mentions légales	Nom(s) des créateurs, hébergeur, contact email.
CGU (Conditions générales d'utilisation)	Règles pour les comptes, favoris, partage public, responsabilité limitée, interdictions d'usage.
Politique de confidentialité	Finalités, bases légales, droits utilisateurs, durées de conservation, destinataires, transferts.
Politique cookies	Description des cookies utilisés + lien vers CMP de consentement.
Charte de la communauté	Comportement attendu (respect, avis constructifs, interdiction d'insultes), procédure de signalement.
Page Transparence (si un jour)	Indiquer les partenariats, affiliations ou offres sponsorisées, s'ils existent plus tard.

- Réaliser un audit sécurité OWASP (injections, accès non autorisés).	
- Tester la charge du site et la restauration de backups .	
- Créer la page “Mes données” pour export/suppression des comptes.	
- Mettre en place un modèle DSAR (réponse aux demandes RGPD).	
- Finaliser le runbook incidents (quoi faire en cas de panne ou fuite).	
- Tester la délivrabilité email (seed list) .	

- Effectuer la check-list finale avant mise en ligne.	

